

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология обнаружения уязвимостей в автоматизированных системах»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №2

«CVE-2025-49844: “RediShell”»

Выполнили:

Доан Тхи Хоай Тхыонг, студентка группы N3445



(подпись)

(подпись)

Проверил:

к.т.н., доц., Менщиков Александр Алексеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025 г.

СОДЕРЖАНИЕ

Содержание.....	2
Введение.....	3
1 Ход работы.....	4
1.1 CVE.....	4
1.2 CVSSv4 (подробно).....	4
1.3 CWE.....	5
1.4 Подходящие техники MITRE ATT&CK.....	5
1.5 Статус наличия эксплойта.....	6
1.6 Перечень диапазонов уязвимых версий.....	6
Заключение.....	7
Список использованных источников.....	8

ВВЕДЕНИЕ

Цель работы - Исследовать и документировать уязвимость CVE-2025-49844 (“RediShell”) в Redis: установить её техническую природу и условия эксплуатации, выполнить оценку риска по CVSS v4.0, сопоставить с CWE и техниками MITRE ATT&CK, определить статус наличия эксплойтов и полный перечень уязвимых версий, а также сформировать практические меры обнаружения и снижения риска для защищаемых систем.

Для достижения поставленной цели необходимо решить следующие задачи:

1. CVE
2. CVSSv4 (подробно)
3. CWE
4. Подходящие техники [MITRE ATT&CK](#), в рамках которых эта уязвимость могла быть использована
5. Статус наличия эксплойта
6. Перечень диапазонов уязвимых версий

1 Ход работы

1.1 CVE

CVE-2025-49844 — Use-After-Free в Lua Redis, приводящая к RCE. Уязвимость существовала ~13 лет в движке Lua Redis; аутентифицированный злоумышленник может отправить специально сформированный Lua-скрипт, чтобы выйти из песочницы и выполнить код на хосте. Исправлено в Redis 8.2.2; если обновление пока невозможно, разработчик рекомендует блокировать EVAL/EVALSHA.

1.2 CVSSv4 (подробно)

Итоговый балл: 8.7 / High

Вектор:

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS
Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS v4.0 Score: **8.7 / High** ⊖

Macro vector: 100200

Exploitability: Medium
Complexity: High
Vulnerable system: High
Subsequent system: Low
Exploitation: High
Security requirements: High

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AT):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	None (N)	<input checked="" type="button" value="Low (L)"/>	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	<input checked="" type="button" value="High (H)"/>	Low (L)
Integrity (VI):	<input checked="" type="button" value="High (H)"/>	Low (L)
Availability (VA):	<input checked="" type="button" value="High (H)"/>	Low (L)

Рисунок 1 - CVSS

- AV:N, AC:L, UI:N: Эксплуатация по сети, взаимодействие с пользователем не требуется.

- PR:L: Нужны права аутентификации/ACL для запуска Lua; многие внедрения оставляют доступ открытым/аутентификация отключена, поэтому фактический риск высок, но по стандарту это всё равно PR:L.
- VC/VI/VA:H: Произвольное выполнение кода → потеря C/I/A в Redis/на хосте.
- SC/SI/SA:N: В описании стандарта не подтверждён эффект на «последующие системы»; оценивается как N.

1.3 CWE

- CWE-416 — Use After Free (библиотека Lua в Redis).

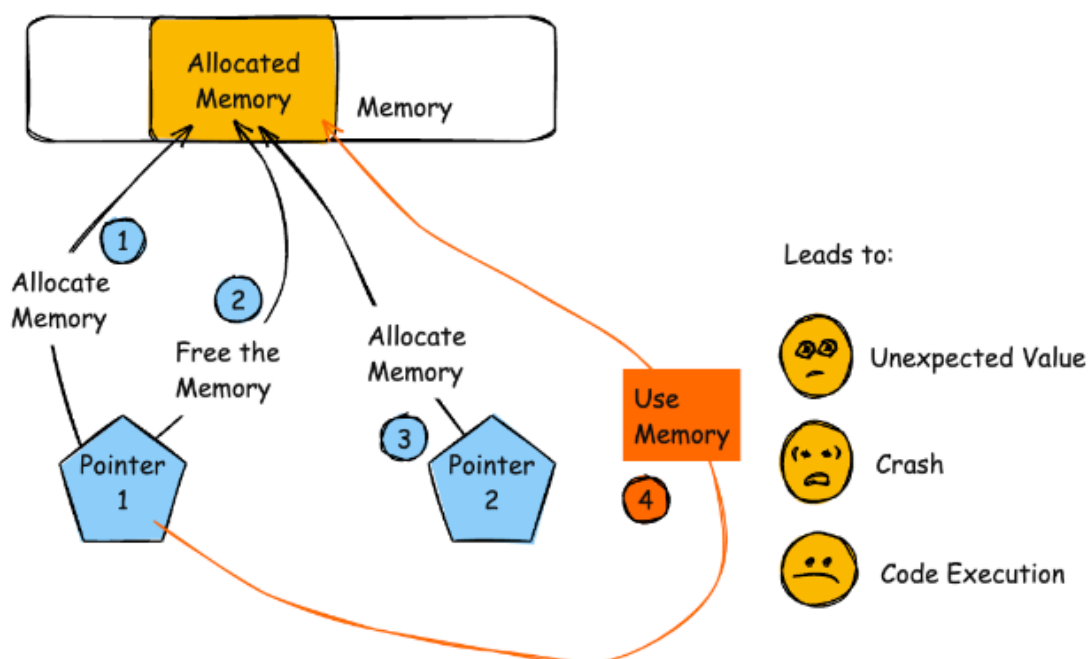


Рисунок 2 - Use After Free

1.4 Подходящие техники MITRE ATT&CK

- T1190 — Exploit Public-Facing Application: если Redis выставлен в интернет (без аутентификации / со слабыми ACL), злоумышленник эксплуатирует публичный сервис для первичного проникновения.
- T1210 — Exploitation of Remote Services: эксплуатация удалённых сервисов во внутренней сети / для латерального перемещения после первоначального взлома, с прицелом на Redis.

1.5 Статус наличия эксплойта

- Публичный PoC (много репозиториях и бюллетени CERT/CSIRT подтверждают наличие PoC).
- Наблюдения сканирования/эксплуатации: многие поставщики предупреждают, а профильные ИБ-ресурсы фиксируют широкомасштабную активность сканирования; рекомендуется немедленно установить исправления.
- KEV (CISA): согласно уведомлению NCSC Ireland, на момент публикации (03–10–2025) в перечень KEV не включена.

1.6 Перечень диапазонов уязвимых версий

- По данным NVD (CPE) — Redis OSS
 - Все версии < 6.2.20
 - Ветка 7.0.x → < 7.2.11
 - 7.4.0 → < 7.4.6
 - 8.0.0 → < 8.0.4
 - 8.2.0 → < 8.2.2 (исправлено в 8.2.2)
- По данным NVD (CPE) — Valkey (форк Redis)
 - ≤ 7.2.10, 8.0.0–<8.0.6, 8.1.0–<8.1.4.
- Согласно advisory Redis (продукты OSS/CE/Stack и Software) — исправленные версии включают:
 - OSS/CE/Stack: 8.2.2+, 8.0.4+, 7.4.6+, 7.2.11+
 - Redis Software: 7.22.2-12+, 7.8.6-207+, 7.4.6-272+, 7.2.4-138+, 6.4.2-131+.

ЗАКЛЮЧЕНИЕ

В ходе работы по уязвимости CVE-2025-49844 (Redis, уязвимость в механизме Lua) достигнуты все поставленные цели: выполнена идентификация CVE, дана техническая характеристика механизма ошибки, проведена оценка риска по CVSS v4.0 с подробным обоснованием метрик, выбрана точная CWE-классификация (CWE-416: Use-After-Free), сопоставлены релевантные техники MITRE ATT&CK (в частности, T1190 и T1210), определён статус наличия эксплойтов и сформирован перечень уязвимых/исправленных версий.

С точки зрения риска, уязвимость опасна из-за сетевого вектора, низкой сложности эксплуатации и высоких воздействий на конфиденциальность/целостность/доступность при наличии возможности исполнения Lua-скриптов. В практических условиях риск дополнительно возрастает при слабых ACL, экспонировании Redis в Интернет и отсутствии сегментации сети.

Рекомендуемые меры снижения риска:

- Немедленное обновление до версий, содержащих исправление, согласно бюллетеням поставщика.
- Компенсационные меры до обновления: ограничить/запретить выполнение Lua (например, отключить EVAL/EVALSHA через конфигурацию/ACL), включить и ужесточить ACL, использовать protected-mode, привязку bind к доверенным интерфейсам, брандмауэр/allow-list на порт 6379, обязательную аутентификацию и TLS.
- Сегментация и принцип наименьших привилегий для узлов с Redis; запрет прямого внешнего доступа.
- Мониторинг и детектирование: журналировать и алертировать вызовы EVAL/EVALSHA, аномалии трафика к Redis, попытки доступа извне, а также признаки последующей эскалации на хосте.
- Проверка устранения: после обновления — повторное сканирование/тесты в лабораторной среде и контроль наличия исправлений конфигурации.

Итог: уязвимость требует приоритета «высокий/критичный» в планах управления уязвимостями. Комбинация оперативного обновления, ограничений на выполнение Lua, жёстких ACL и сетевой изоляции позволяет существенно снизить вероятность успешной эксплуатации и потенциальный ущерб, а встроенные процедуры мониторинга — своевременно выявлять попытки её эксплуатации.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. [Redis Server Use-After-Free Vulnerability Allows Remote Code Execution](#)
2. [CWE-416: Use After Free \(4.18\)](#)
3. [NVD - CVE-2025-49844](#)
4. [MITRE ATT&CK®](#)
5. [Common Vulnerability Scoring System Version 4.0 Calculator](#)